



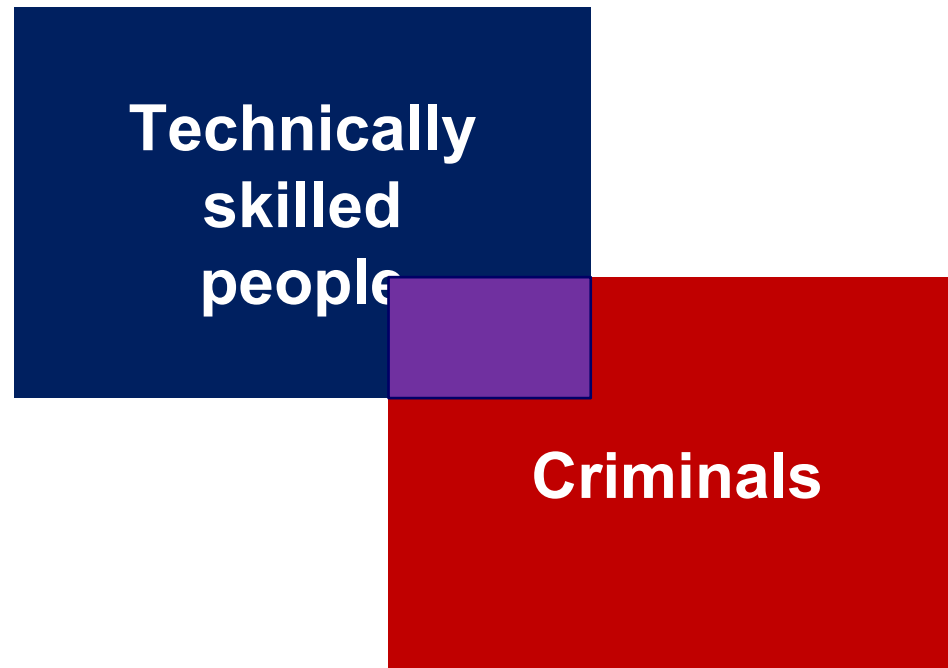
ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Cyber Threat Intelligence

Michele Colajanni

Dipartimento di Informatica – Scienza e Ingegneria
michele.colajanni@unibo.it

Besides motivations, there are two types of threat actors



Cybercrime is a mature industry

1. Vertical criminal specialization

2. Markets for exchange: *de facto* open virtual spaces

a) **Criminal marketplace:** (similar to e-commerce sites)

- Sales areas / purchase spaces
- Advertisements and offers
- Cryptocurrency payments
- Trust on (criminal) sellers based on continuous feedbacks

b) **Hidden forum:** closed circles based on invitation (ethnic groups, ideologies, groups of interest, ...)

3. Crime as a Service

- Developers, administrators and moderators of black-market platforms



Vertical criminal specializations

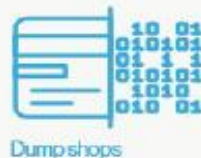
1 Services



2 Distribution



3 Monetization



Types of cyber criminals

1) Actors

2) Facilitators

- Login/password
- Software vulnerabilities
- Exploit, 0-day
- Money laundering
- Administrators and moderators of black markets
- Developers of “integrated” platforms

2) Third parties

- Moderators of Dark markets
- Escrow of the Dark Web
- CaaS platforms



Different layers in the cyberspace

World Wide Web

(indexed resources by Google, Bing, Yahoo)

DEEP Web

(non indexed resources)

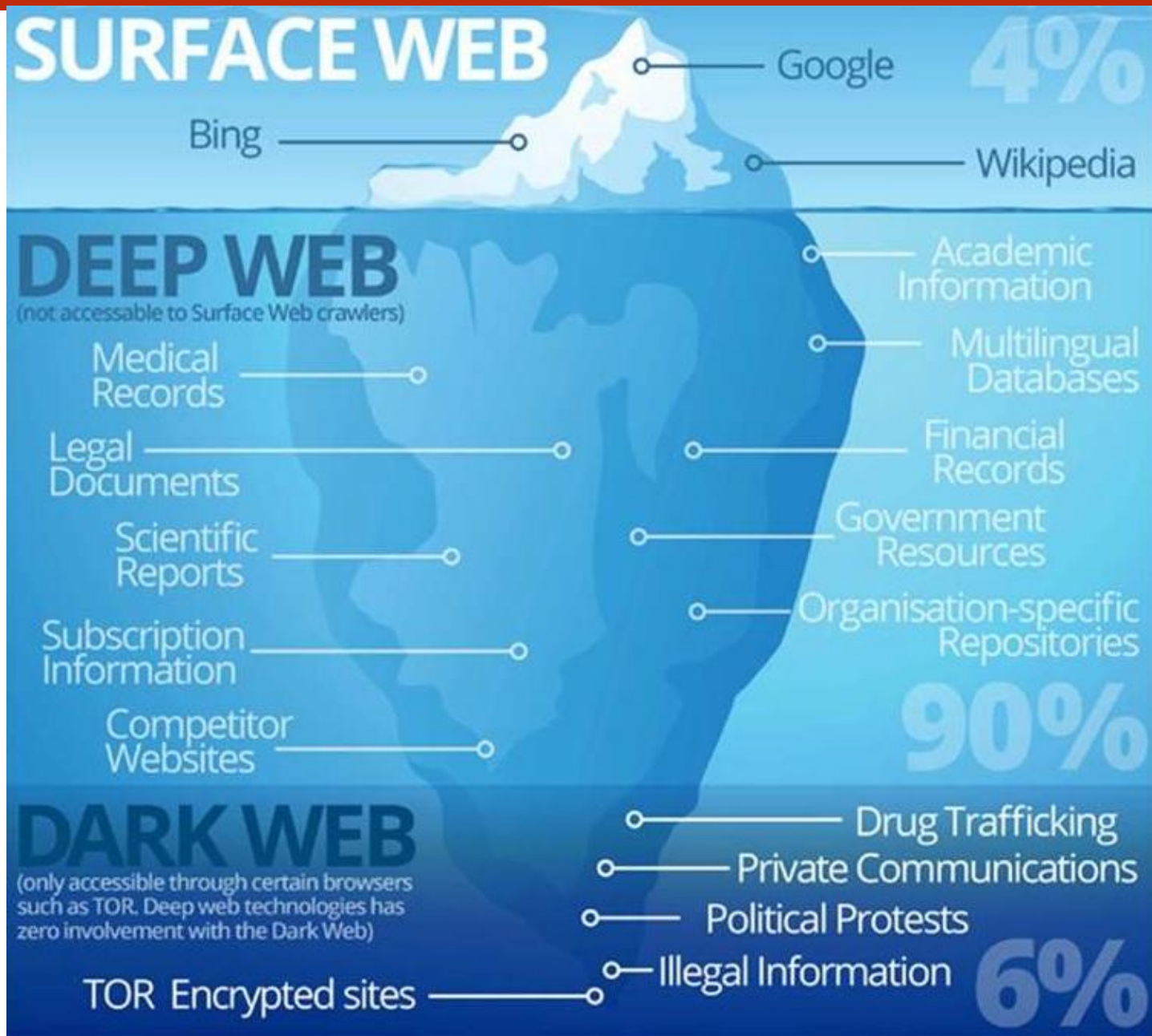
Cyber FORUM



HIDDEN FORUM



The main three layers



Cyber Forum



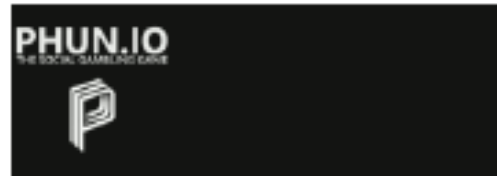
Join Today

[Home](#) [Upgrade](#) [Search](#) [Memberlist](#) [Extras](#) [Help](#) [Wiki](#) [Follow](#) [Contact](#)

Hello There, Guest! [Login](#) [Register](#)

Current time: 04-14-2018, 12:07 AM

Hack Forums



[Common](#) [Hack](#) [Tech](#) [Code](#) [Game](#) [Groups](#) [Web](#) [GFX](#) [Market](#) [Money](#) [World](#)

Hacks, Exploits, and Various Discussions



Forum		Threads	Posts	Last Post
	Beginner Hacking This is for the entry level hacker wishing to learn more about the art of h4(k5). Moderated By: Mentors E-Whoring Private Investigation Methods and Anonymity Worms, Malware, and Viruses	229,645	1,791,495	regarding amazon gift car... 2 minutes ago by white shinobi
	Advanced Hacking If you feel you're past the beginner stages and want to delve deeper into computer security, analysis, and internet exploits you should participate here. Botnets, IRC Bots, and Zombies Pentesting and Forensics Cryptography, Encryption, and Decryption Decompiling, Reverse Engineering, Disassembly, and Debugging	115,318	942,982	Pink-Panther's AUTOMATED ... 35 minutes ago by superm008

Cyber Forum



[Home](#) [Upgrade](#) [Search](#) [Memberlist](#) [Extras](#) [Help](#) [Wiki](#) [Follow](#) [Contact](#)

Join Today

Hello There, Guest! [Login](#) [Register](#)

Current time: 04-14-2018, 12:07 AM

Hack Forums



[Common](#) [Hack](#) [Tech](#) [Code](#) [Game](#) [Groups](#) [Web](#) [GFX](#) [Market](#) [Money](#) [World](#)

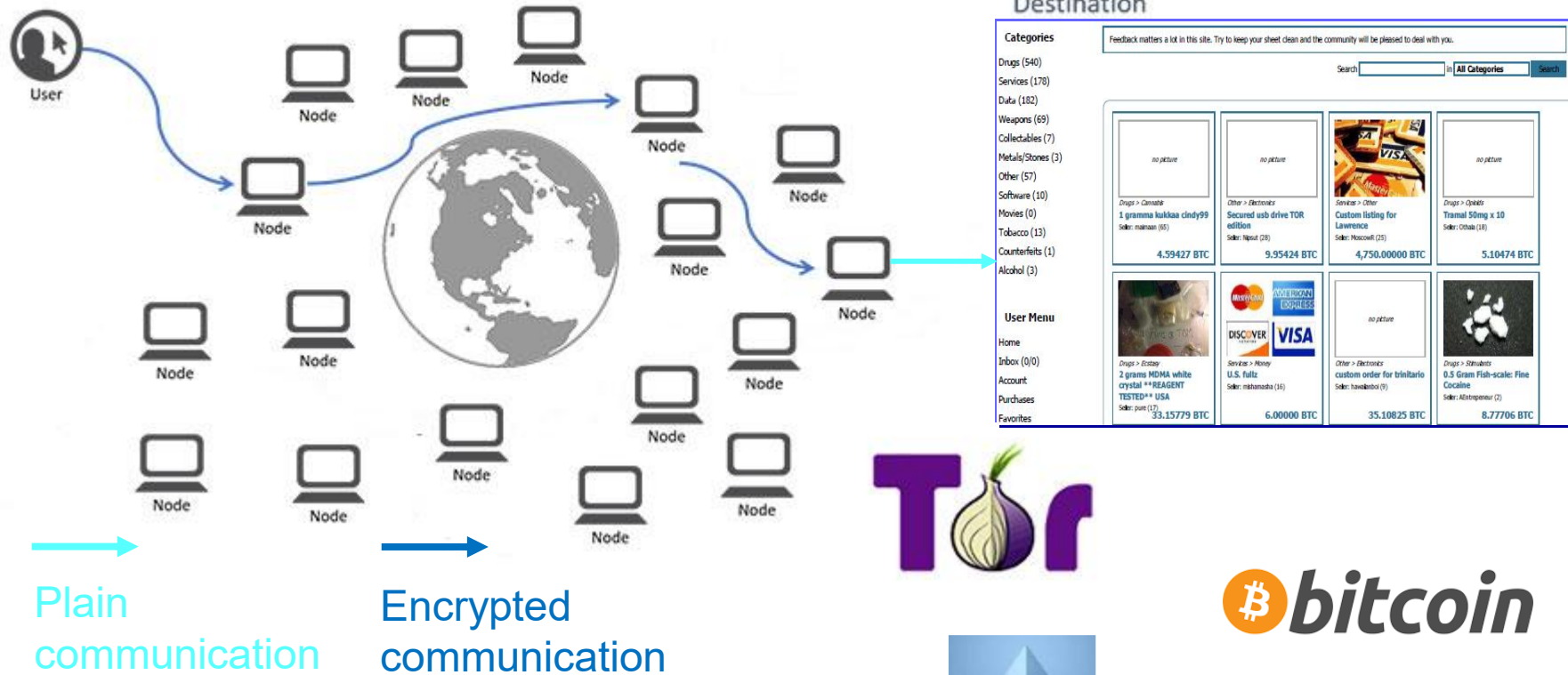
Marketplace



Forum		Threads	Posts	Last Post
	Marketplace Discussions This is to be used for rules, policies, feedback, and general discussions about the HF Marketplace. Please read the stickies in this section before conducting business here. Free Services and Giveaways Appraisals and Pricing Deal Disputes	221,078	2,986,303	Learn How To Start Your O... 25 minutes ago by CYB3RM4N
	Premium Sellers Section This area is only for upgraded member sales threads. Premium Tools and Programs Cryptography and Encryption Market	86,110	1,599,858	AUTOCASH V2.0 @ AUTOPILOT... 8 minutes ago by Ombra
	Secondary Sellers Market This is a sellers section open to all members. We advise extreme caution in all deals here. Sales threads must follow the policies of HF and we expect you to read them in the help documents. Virtual Game Items Member Auctions	233,772	1,418,685	[H] 07 Gold 147m+ [W] Cry... 15 minutes ago by Drine2

Dark Market ingredients: TOR + Crypto-currency

The Onion Router (TOR) Network



Products with best revenue (~80%) in the Dark Market?

- 1) Credit cards and credentials (login / password)
- 2) Data (people, medical records, financial ratings, etc.)
- 3) Drugs and medications 
- 4) Copyrighted material
- 5) Weapons
- 6) Documents (passports, identity, driving licenses, diplomas, certificates)
- 7) Malware and services for cyber attacks
- 8) Murders on commission
- 9) Persons (for prostitution and semi-slavery work)
- 10) Child pornography material
- 11) Organs for transplants
- 12) Hoax, fraud



Drugs

AREA51

1 ₮ = 351.54\$

orders: 0 messages: 0 settings logout

search...

0.000000 ₮

Get help

DRUGS

BENZOS (31)

CANNABIS (82)

DISSOCIATIVES (1)

ECSTASY (26)

OPIOIDS (22)

OTHER (4)

PRECURSORS (0)

PRESCRIPTION (2)

PSYCHEDELICS (11)

STEROIDS/PED (2)

STIMULANTS (89)

ALCOHOL

ABSINTH (0)

WHISKY/BOURBON (0)

DIGIT. GOODS

FRAUD (29)

GAMING / CARDS (1)

SOFTWARE (1)

DOCUMENTS

DRIVER LICENSES (0)

IDS (3)

OTHERS (1)

OTHERS

DRUG PARAPHERNALIA (2)

ELECTRONICS (2)

OTHERS (5)

WEAPONS

BLADE-WEAPONS (1)

sort by: Date(Newest) | ship from: Everywhere | ship to: Everywhere | update

u again ? really ? gwern

Heroin 1.00g (white-rock)

Vendor: AuStore

Ships from: Australia

1.27722 ₮

Heroin 0.50g (white-rock)

Vendor: AuStore

Ships from: Australia

0.65141 ₮

Heroin 0.25g (white-rock)

Vendor: AuStore

Ships from: Australia

0.39540 ₮

10x Dutch LSD Shiva print 180ug LAB TESTED!- COPY

Vendor: Tr4derJo3

Ships from: Germany

0.28446 ₮

5x Dutch LSD Shiva print 180ug LAB TESTED!

Vendor: Tr4derJo3

Ships from: Germany

0.15076 ₮

25x Dutch LSD Dalai Lama 225ug LAB TESTED!

Vendor: Tr4derJo3

Ships from: Germany

0.86760 ₮

10x Dutch LSD Dalai Lama 225ug LAB TESTED!

5x Dutch LSD Dalai Lama 225ug LAB TESTED!

12x Iced Grapefruit F2 Female Seeds *special price!

50g Jack Herer A+++ Coffeshop Quality Weed

20g Jack Herer A+++ Coffeshop Quality Weed

10g Jack Herer A+++ Coffeshop Quality Weed

ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Michele Colajanni - Threat modeling, 2026

12

A lot of drugs

[illegible]

Dream market (mainly for drugs) – now closed

Browse by category

- **Drugs 40336**
 - ▶ Barbiturates 43
 - ▶ Benzos 1947
 - ▶ Cannabis 10839
 - ▶ Dissociatives 1262
 - ▶ Ecstasy 6977
 - ▶ Opioids 3453
 - ▶ Prescription 1863
 - ▶ Psychedelics 3288
 - ▶ RCs 340
 - ▶ Steroids 986
 - ▶ Stimulants 6906
 - ▶ Weight loss 125

- ▶ Digital Goods 29781
- ▶ Drugs 40336
- ▶ Drugs Paraphernalia 525
- ▶ Services 2216
- ▶ Other 2038

Exchange

USD	740.1
EUR	703.9
CAD	987.5
AUD	1006.6
GBP	598.0
SEK	6915.2
NOK	6403.4
DKK	5237.6
TRY	2517.4
CNH	5239.9
RUB	48241.5
JPY	82351.2

Onion mirrors

Ichudifeyqm4ldjj.onion
 jd6yhuwcivehvd4.onion
 t3e6ly3uoi4zcv2.onion
 7enZackunzdcw3l.onion

Drugs (40351)

Filter

Ships to	Ships from	Escrow	Category
			Drugs
Price	Searchtext	Sort by	Vendor
€ -			All

Apply filter

1 2 3 4 5 6 7 8 9 10 11 12 13 14 15 16 17
 18 19 20 ... 1252 1253 1254 1255 1256 1257 1258 1259 1260 1261 →

3.5g Pure Cocaine Very High Quality 90-95%



ESCROW

€0.3979

hammerhome123 (2804)
 (4.93★)
 GB – GB, EU

Order

28g Mdma



NO ESCROW

€0.551

project-4 (1597) (4.91★)
 GB – WW

Order

★25x180UG★Cali Blotter★



NO ESCROW

€0.1519

Doug-Heffernan (1074)
 (4.82★)
 EU – WW

Order

★100x100UG★The Beatles Blotter★



NO ESCROW

€0.426

Doug-Heffernan (1074)
 (4.82★)
 EU – WW

Order

50 x Red Devil Ecstasy PILLS. - 170mg MDMA - Ecsta



NO ESCROW

€0.234

InsideTheWhale (2312)
 (4.94★)
 GB – EU, GB

Order

200 Empty Carts/ Caps and Sleeves!!!



ESCROW

€0.54

GoodCatKilla (1231) (4.97★)
 US – US

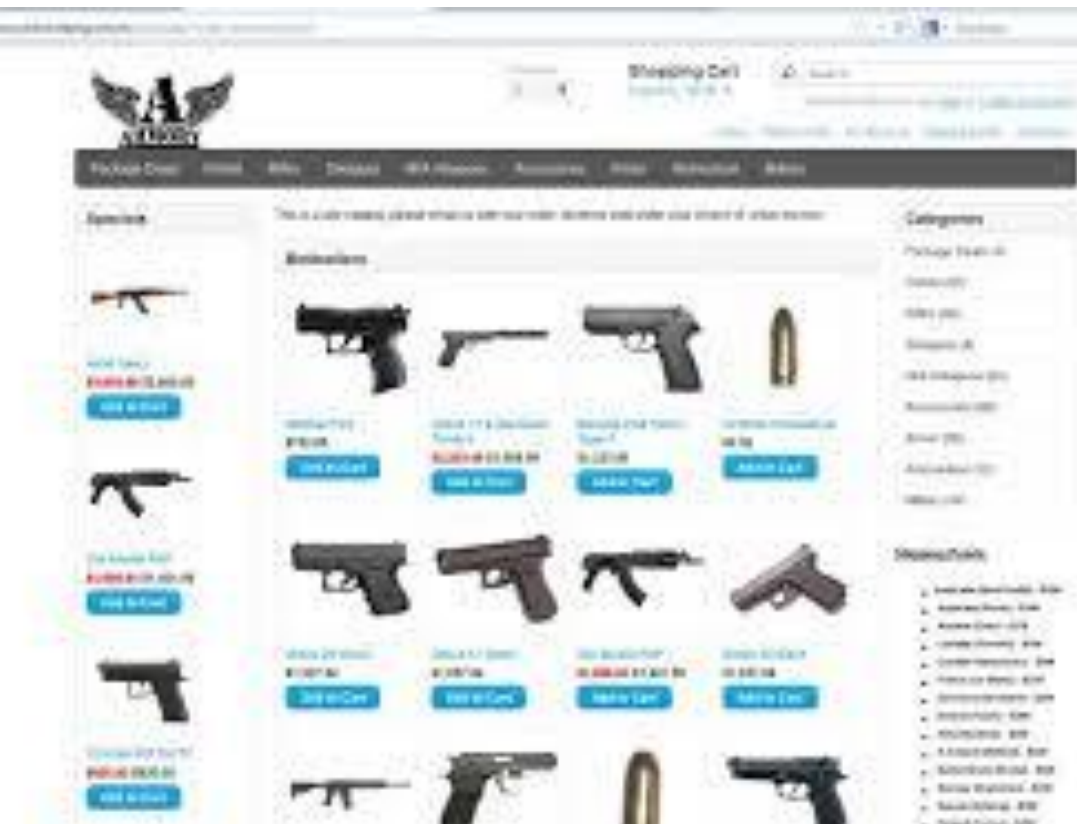
Order



Username/password



Weapons and Passports



High School

Diploma

From \$75, they look and feel just like those from a real school! Choose a state seal in raised "puffy" gold ink or fully embossed gold foil stickers. Different paper colors and sizes too.



Diploma & Transcript



Transcript



College & University

Diploma

From \$125, Fake Diplomas for College, Fake Transcript for College, Fake Diploma and Transcript Package for College, "Actual Match" designs based on original layouts, wording, emblems or budget-friendly "Regional Designs". Top quality diploma parchment paper, fully customized for most degrees and majors.



From Your Scan

From \$250, email us a scan of an original. We'll recreate the graphics with your text changes. NOT cheap "cut and paste" - fully recreated. Prompt price quotes for all levels of complexity.



Send Us Your Scan
CLICK HERE

Certificates

From \$250, they look and feel just like those from a real school! Different paper colors and sizes too.



But also a lot of ...

Scams and Fraud

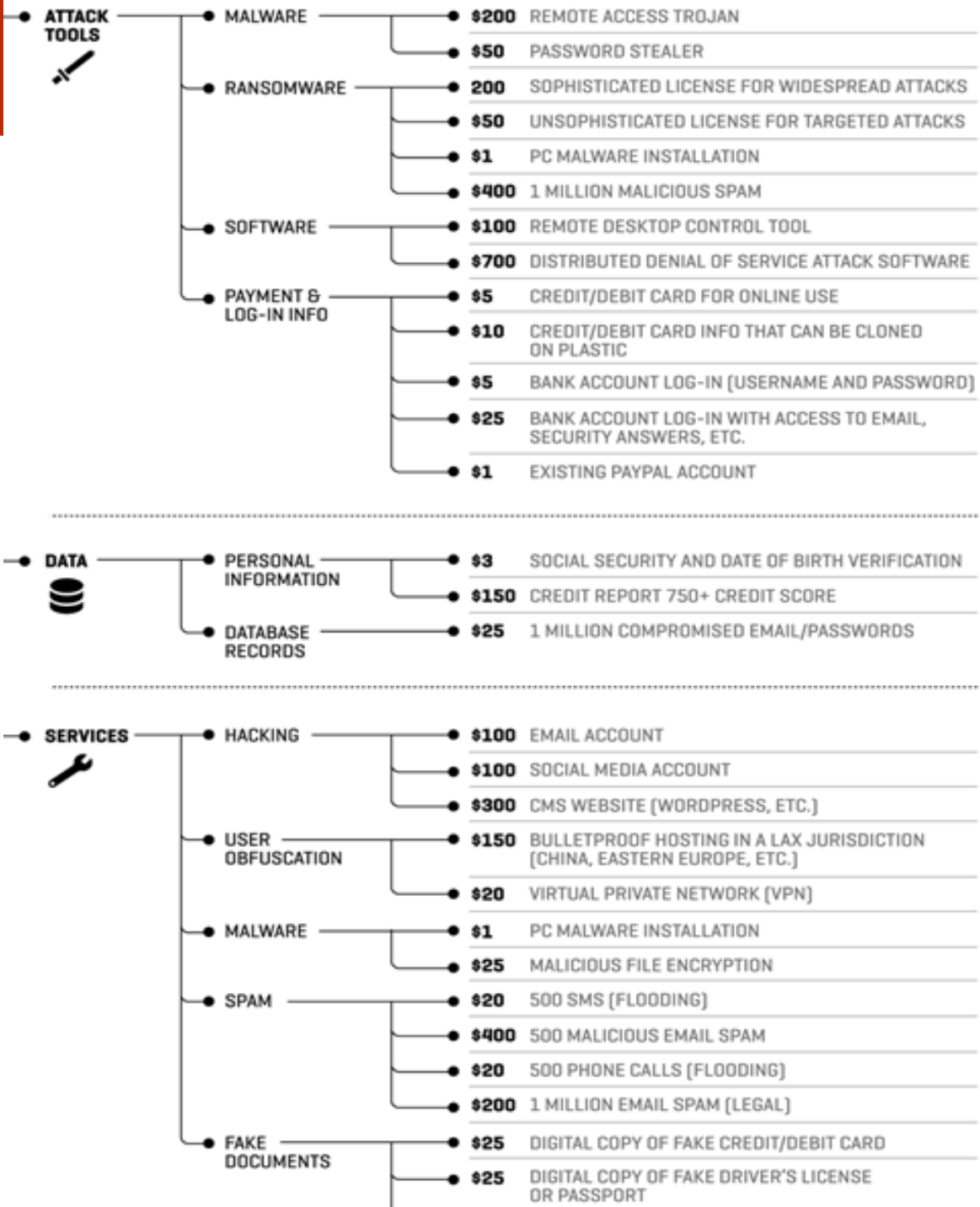


Cyber threat vectors on sale

- Ransomware, e.g.,
 - Locky
 - CryptXXX (first decryption for free; next at 500\$)
 - Cerber
 - Cerber 2.0
- RAT, RCE, Trojan, ...
- DDoS
- Keylogger
- Stolen login/password



Cyber tools



Crime as a Service (CaaS)

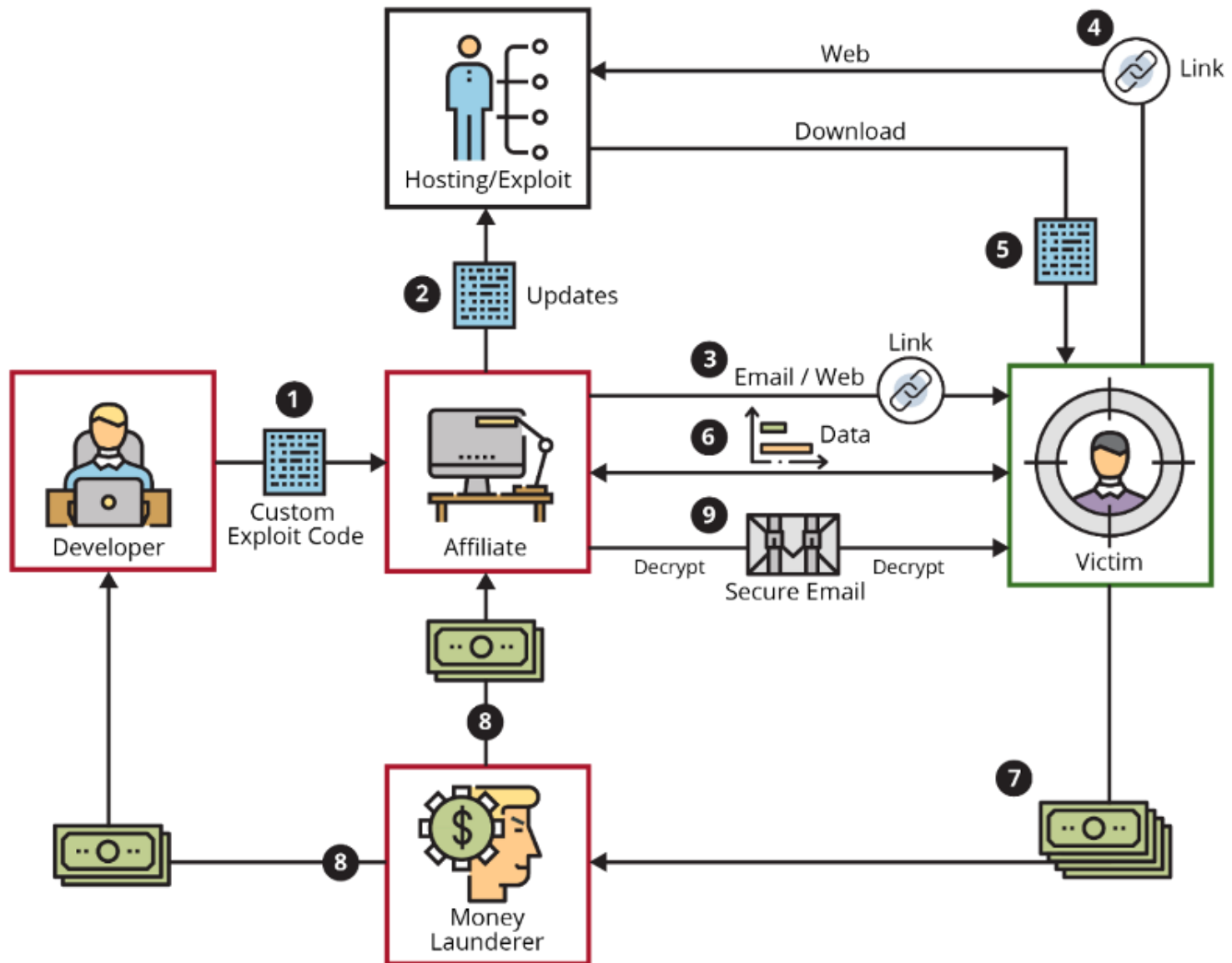
Criminals offer a wide range of skills and technological solutions to potential buyers

1. Some services are provided on a tailor-made basis and can be adapted to customers' specific needs:
 - competent criminals who wish to perpetrate targeted attacks
 - people without particular technical skills who intend to commit some criminal activities online
2. Sale of criminal tools and infrastructure for rent: malicious software, botnet, compromised accounts, advanced methods
3. Professional technical support

Many CaaS offer continuous assistance to customers, guaranteeing them access to technical advice, regular updating of services, assistance in tool configuration, money-back guarantees in case of failure. Everything is paid in cryptocurrency



Example: *Ransomware as a Service*



Ransomware as a Service (RaaS)

RaaS	Technique	Big Game Hunter
DarkSide	DarkSide operators traditionally focus on Windows machines and have recently expanded to Linux, targeting enterprise environments running unpatched VMware ESXi hypervisors or stealing vCenter credentials. DarkSide RaaS is also believed to be the attack vehicle leveraged in the high-profile Colonial Pipeline attack.	CARBON SPIDER
REvil (also known as Sodinokibi)	REvil is a RaaS most commonly used by PINCHY SPIDER. In such attacks, victims usually receive a warning of an impending data leak if a ransom is not paid. REvil is credited with being the ransomware behind one of the largest ransom demands on record: \$10 million USD.	PINCHY SPIDER
Dharma	Dharma ransomware attacks are mainly associated with remote desktop protocol (RDP) attacks. Dharma variants come from many sources and are nearly identical in nature, making it difficult to ascertain who is behind an attack.	Linked to a financially motivated Iranian threat group Not centrally controlled
LockBit	In development since 2019, LockBit attacks demand a ransom to avoid the publication of a stolen data set. The RaaS is confirmed to have been involved in at least nine attacks.	Affiliated with Russian-speaking users or English speakers with a Russian-speaking guarantor



A huge, but typical cyber attack

UnitedHealth Group, the largest U.S. multinational operating in the health insurance and medical-healthcare services sector, was equipped with multiple cyber certifications:

- ISO/IEC 27001
- Health Information Trust Alliance (HITRUST)
- Payment Card Industry (PCI)



***Also essential for
cyber insurance
purposes***

and *Multi-Factor Authentication* (MFA) on all computers

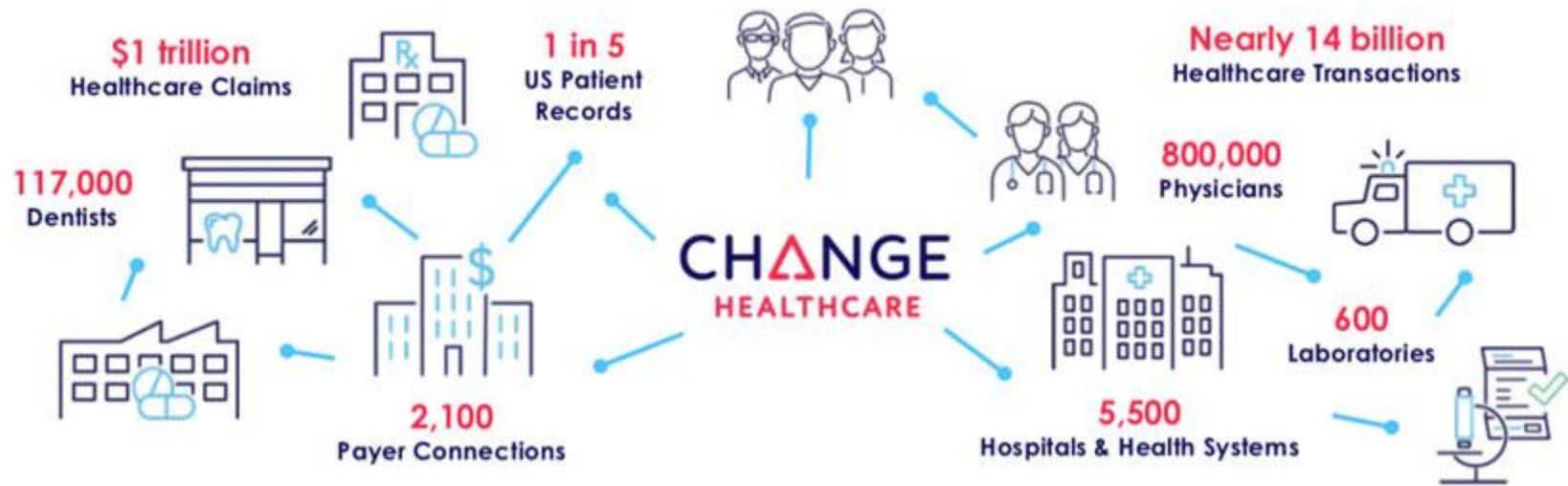
In **October 2022**, UnitedHealth Group bought **Change Healthcare** for about 13 B\$

In **February 2024**, Change Healthcare it received a **ransomware attack** on a subsidiary of UnitedHealth Group that represented a perfect example of a **systemic risk caused by a recently acquired, less cybermature company**



Attack against Change Healthcare (2024)

CHANGE
HEALTHCARE



Change Healthcare was the provider of revenue and payment cycle management services connecting payers, providers, doctors and patients within the U.S. healthcare system. It uses AWS PaaS services to handle millions of confidential transactions **daily**



Cyber Attack

- The ransomware attack against Change Healthcare took advantage of a weak authentication (not protected by MFA)
- It caused
 - a prolonged outage that severely hampered claims processing across the entire US healthcare system, pushing thousands of smaller physician practices to the brink of financial collapse
 - Theft of confidential health data
 - Threat of publication



Right motivation for the cyber insurance not to reimburse the company for the incident



The attack (1/3)

- The attack was carried out by a ransomware group known as **ALPHV**, also widely referred to as **BlackCat**. The attackers gained initial access to Change Healthcare's network on February 12, 2024 through just one server that **lacked the crucial Multi Factor Authentication (MFA) security measure** that was adopted in all other servers.
- The attackers used compromised credentials to access this server, which was part of a Citrix remote access service
- After gaining initial access, the attackers spent approximately nine days moving laterally through Change Healthcare's network, exfiltrating a significant amount of data
 - Substantial amount of **data was stolen** (estimated **192.7 million individuals**) between February 17 and February 20
 - On 21 February, the attackers deployed **ransomware**, encrypting Change Healthcare's systems and rendering them inaccessible



The attack (2/3)

- The company responded by immediately taking over 100 systems offline to contain the spread of malware
- The BlackCat group demanded a ransom and in an effort to protect patient data from being leaked, UnitedHealth Group's subsidiary Optum paid a ransom of approximately \$22 million in Bitcoin
- The situation became even more complicated because BlackCat, which operated as a **Ransomware-as-a-Service**, pulled an **exit scam**, shutting down its operations and pocketing the full ransom without paying the **affiliate** who was responsible for the initial breach
- This affiliate took a copy of the stolen data to another ransomware group, **RansomHub**, which then demanded a second ransom, but UnitedHealth Group decided not to make a second payment



The attack (3/3)

- This decision had a catastrophic impact, because **RansomHub** exposed all health information of an estimated **192.7 million** people, making it the largest healthcare data breach on record. The stolen data included names, dates of birth, contact information, Social Security numbers, and medical information
- Moreover, the unavailability of Change Healthcare's systems:
 - froze the revenue cycle for thousands of hospitals, physician practices, and pharmacies
 - led to a national liquidity crisis, with many providers unable to file claims, receive payments, or even verify patient eligibility
 - had consequences for patient care, with reports of delays in pre-authorizations for medical procedures and other disruptions to clinical operations
 - the financial impact was severe, with costs in the billions of dollars. (the American Hospital Association reported that some large health systems were losing more than \$100 million daily)



Lessons learned

- 1) A just-acquired third-party SaaS provider can cause a stop to an entire industry
- 2) Modern third-party SaaS providers leverage PaaS of important cloud providers (AWS, DCP, Azure)
- 3) Cyber certifications (even three!) do not guarantee cybersecurity
- 4) Just one vulnerability can cause an IT system compromise
- 5) The cyber insurance did not reimburse the company
- 6) ...



Specialized companies



Cyber threat actors and motivations



Nation State Actors

[96%]

Advanced Persistent Threats

Criminals

Professionals

Specialized companies

Contractors

Malware market (vulnerability, exploit, trojan)

Data brokers



Cyber threat actors and motivations



Nation State Actors

[96%]

Advanced Persistent Threats

Criminals

Professionals

Specialized companies

Contractors

Malware market (vulnerability, exploit, trojan malware)

Data brokers



Specialized companies (market of ~80B\$/year)



Specialized companies: government *trojan* market

- “Terrorists, drug traffickers, pedophiles, and other criminals have access to advanced technology designed to shield their communications, while government intelligence and law-enforcement agencies struggle to collect evidence and intelligence on their activities.
- Due to these ongoing global concerns, the member nations warn that, “The increasing gap between the ability of law enforcement to lawfully access data and their ability to acquire and use the content of that data is a pressing international concern that requires urgent, sustained attention.”
- We develop best-in-class technology to help government agencies detect and prevent a wide-range of local and global threats. **Our products help government intelligence and law-enforcement agencies use technology to meet the challenges to prevent and investigate terror and crime.”**



(In)famous products

Banking trojans:

- Alien, Cerberos, Dridex, Godfather, Hydra, Nexus, Xenophorm, ...

Spyware trojans:

- DevilsEye, DevilsTongue (Candiru, Israel)
- Pegasus (NSO, Israel)
- Predator (Intellexa, Ireland)
- (Cytrox, Macedonia)
- ...

<https://citizenlab.ca/>

<https://www.bleepingcomputer.com/news/security/predator-looking-under-the-hood-of-intellexas-android-spyware/>



Enough is enough! *(at least for some democratic countries)*

Example US

<https://foreignpolicy.com/2023/07/31/spyware-nso-cytrox-intellexa-pegasus-predator-biden-sanctions-entities-list-israel-europe/>

Example Germany

<https://therecord.media/new-german-government-coalition-promises-not-to-buy-exploits>

after a different previous decision

<https://www.euractiv.com/section/digital/news/civil-society-tech-giants-oppose-germanys-state-trojans-plans/>

<https://youtu.be/fETKbv6kkas>



Specialized companies: *zero-days* market

ZERODIUM is the world's leading exploit acquisition platform for premium zero-days.



We pay BIG bounties to security researchers to acquire their original and previously unreported zero-day research.

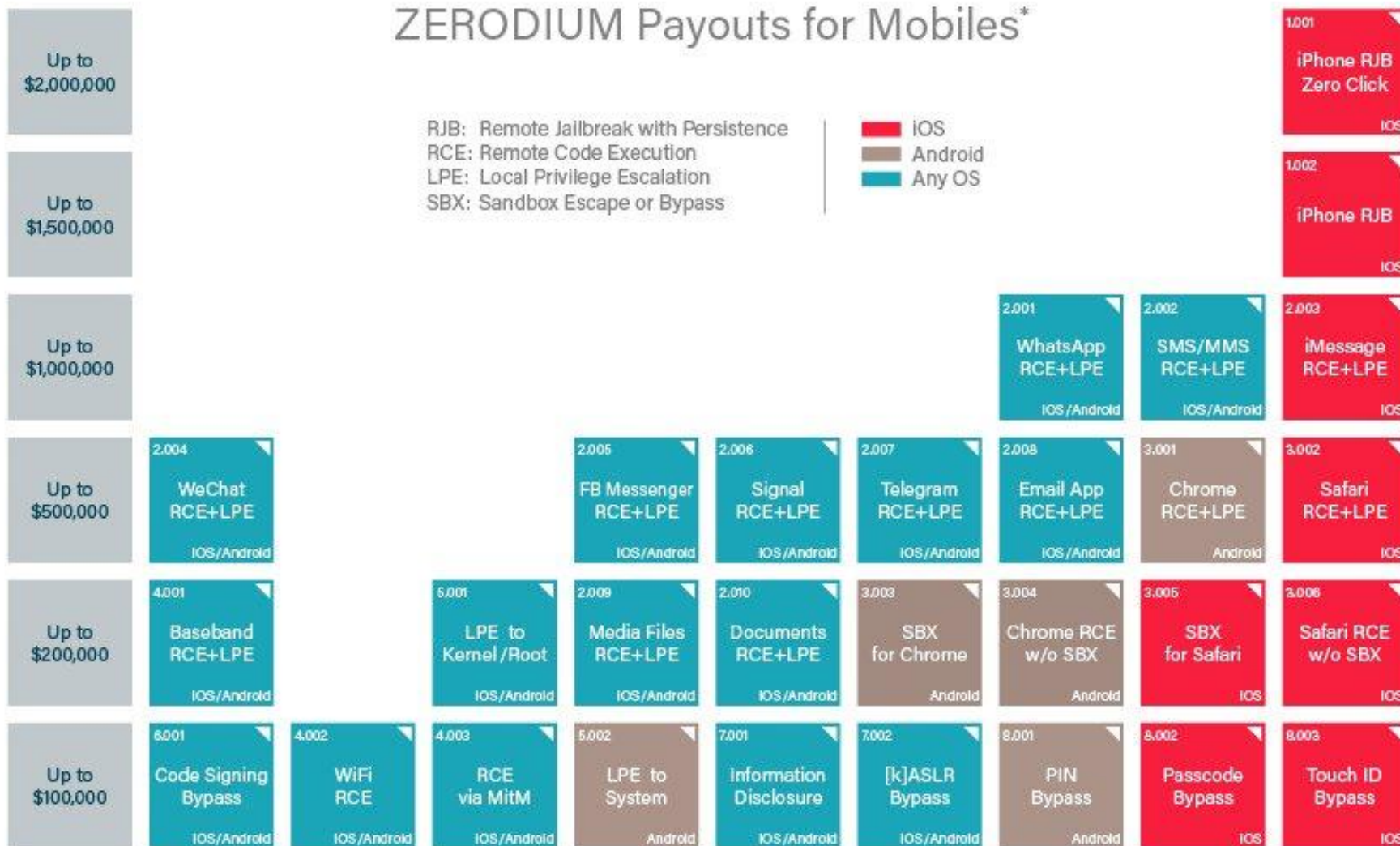
While the majority of existing bug bounty programs accept almost any kind of vulnerabilities and PoCs but pay very low rewards, **at ZERODIUM we focus on high-risk vulnerabilities with fully functional exploits** and we pay the highest rewards (**up to \$2,500,000 per submission**).

ZERODIUM is currently acquiring zero-day exploits and innovative security research related to: operating systems, Web browsers and servers, applications, smartphones (Apple, Google, Samsung, LG, Huawei, OPPO, Sony, HTC, Xiaomi, BlackBerry), e-mail servers



Prices: exploits for smartphones

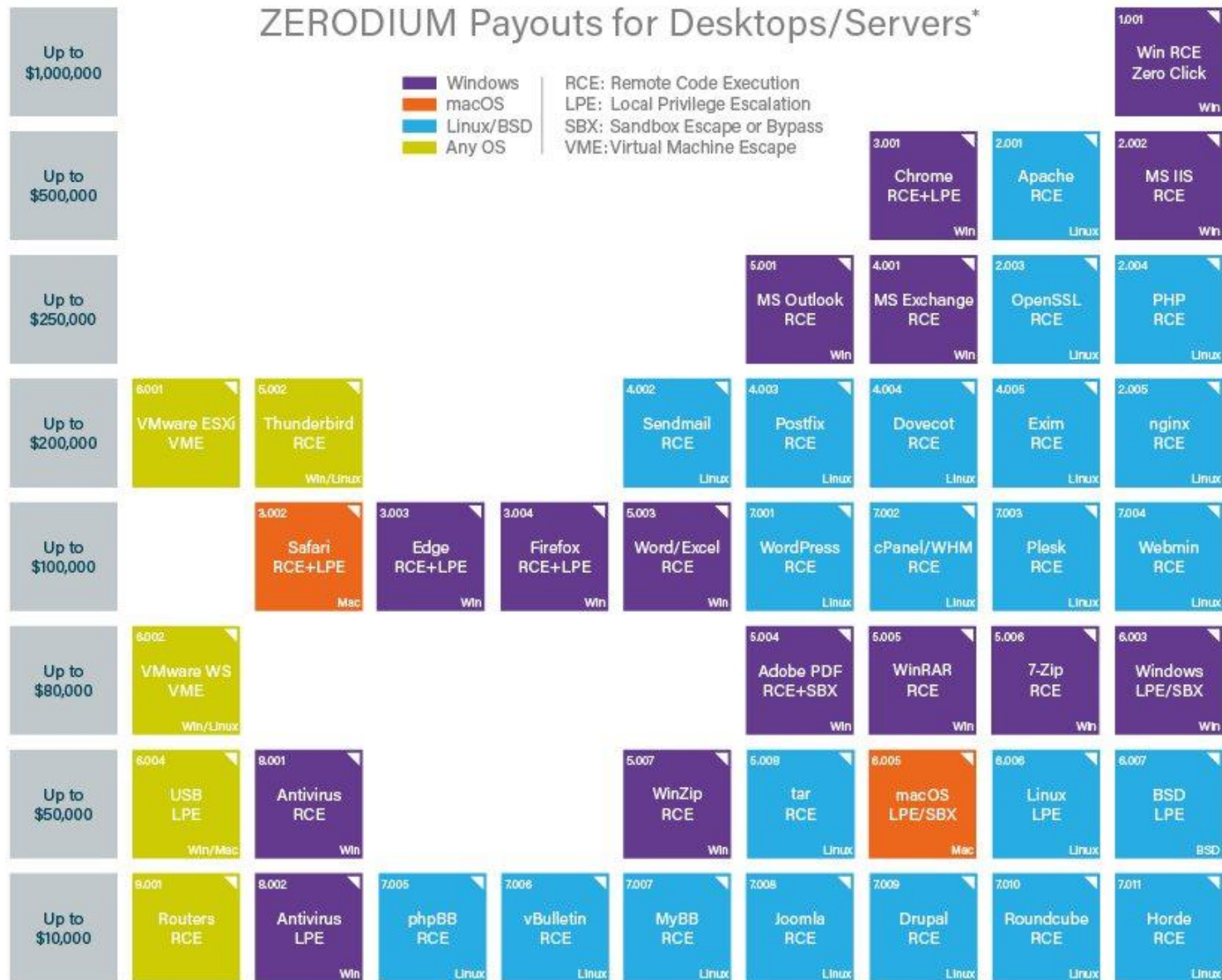
ZERODIUM Payouts for Mobiles*



* All payouts are subject to change or cancellation without notice. All trademarks are the property of their respective owners.

2019/01 © zerodium.com

Prices: exploits for computers and servers



* All payouts are subject to change or cancellation without notice. All trademarks are the property of their respective owners.

2019/01 © zerodium.com



Specialized companies: *in which color scale are they?*

Specialized companies

Democratic States against *terrorists* and *criminals*

Dictatorships against *terrorists* and *criminals* but also against *journalists*, *political opponents* and other “unwanted” categories

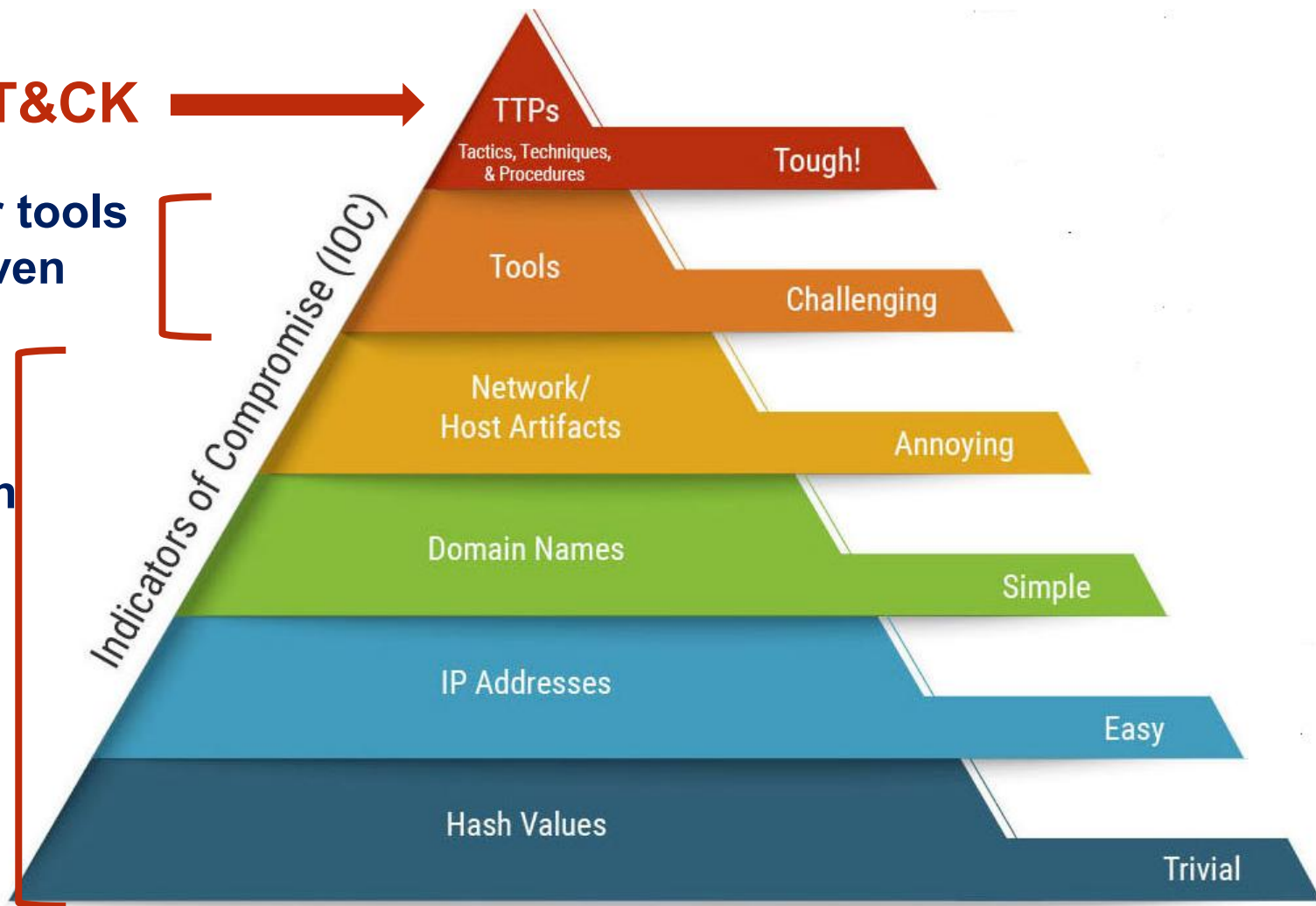


David Bianco's Pyramid of Pain: *Where to use what?*

MITRE ATT&CK →

The **best** cyber tools can address even these issues

Most prevention and detection cyber tools can manage these attacks automatically



The Pyramid of Pain



Professional groups working on CTI

- CISCO Talos
- CrowdStrike Falcon X
- ESET Threat Intelligence
- FireEye
- IBM Security X-Force
- Mandiant Threat Intelligence
- McAfee
- MITRE
- Google Mandiant
- Palo Alto Networks Cortex
- Recorded Future Intelligence Platform
- ZeroFox
- ...

*You cannot protect something
from what you do not know*



MITRE tries to address the lack of standards issue

No common names, analyses structures, Indicators of Compromise (IoC), conclusions

MITRE is trying to address these issues

